

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE CODE: CSA5117

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 50

Annexure A

Industry Problem-Solving Task

Code of Conduct:

*I Harshini R N (192421175) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student: Harshini R N

Annexure A Industry Problem-Solving Task

1. A multinational enterprise is deploying IPsec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPsec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
2. An organization faces frequent key management issues in its IPsec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
- B. Analyze email headers for spoofing indicators
- C. Design an improved detection model (rule-based or ML-based)
- D. Evaluate effectiveness and false positive handling

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

1. IPSec Deployment for a Multinational Enterprise

A. Traffic Requiring AH, ESP, or Both

- **AH:** Provides authentication, integrity, and protection against packet modification. It does **not** provide confidentiality.
- **ESP:** Provides confidentiality through encryption and can also provide integrity and authentication.
- **AH + ESP:** Can be used when both AH-specific authentication and ESP encryption are required, although ESP with authentication is normally sufficient.

Traffic Type	Recommended Protocol	Reason
Confidential financial data	ESP	Encryption + integrity
General business data	ESP	Protects confidentiality and integrity
Public/non-sensitive data	AH or ESP	Integrity is the primary requirement
Highly sensitive traffic	ESP with authentication	Strong confidentiality and integrity
Site-to-site branch traffic	ESP Tunnel Mode	Protects complete IP packets

B. Packet Flow and IPSec Modes

Site-to-site communication:

```
Branch A
|
Original IP Packet
|
ESP Tunnel Mode
|
Encrypted Outer IP Packet
|
==== Public Internet ====
|
ESP Decapsulation
|
Original IP Packet
|
Branch B
```

Transport Mode:

```
Original IP Header + TCP/UDP + Data
      ↓
    ESP Transport
      ↓
IP Header + ESP + Encrypted Payload
```

Transport mode is mainly suitable for host-to-host communication.

Tunnel mode encapsulates the complete original IP packet inside a new IP packet and is preferred for communication between branch-office gateways.

C. Protocol Selection

ESP is preferred for most enterprise traffic because it provides both **confidentiality and integrity**. AH should be used only when authentication of the IP header and payload is specifically required.

For branch-to-branch communication, **ESP tunnel mode** is the recommended configuration because it protects the complete internal IP packet while allowing secure communication across the public Internet.

D. Performance vs Security Trade-offs

- AH has lower processing overhead because it does not encrypt data.
- ESP requires additional CPU and bandwidth because of encryption and authentication.
- Tunnel mode adds an additional IP header and therefore increases packet size.
- Modern hardware acceleration can significantly reduce ESP encryption overhead.
- For sensitive enterprise traffic, the security benefits of ESP generally outweigh its performance cost.

Conclusion: Use **ESP with authenticated encryption in tunnel mode** for branch-to-branch traffic and use transport mode where direct host-to-host protection is required.

2. IPSec Security Association and Automated Key Management

A. SA Lifecycle Issues

Common problems include:

- Expired SAs not being removed or renewed properly.
- Different encryption or authentication parameters at two endpoints.
- Key mismatch between peers.
- Incorrect lifetime configuration.
- Manual key configuration errors.
- Failure to synchronize security policies.
- Lack of proper SA monitoring.

These problems can cause communication failures and security weaknesses.

B. Automated IKE-Based Key Management

An **IKE (Internet Key Exchange)** based system should be deployed.

```
Initiator                                Responder
|                                         |
|---- IKE negotiation ----->|
|<--- Authentication -----|
|---- Security parameters ----->|
```

```
|<--- Key agreement -----|
|                             |
|===== IPSec SA Established =====|
|                             |
|<===== Encrypted Traffic =====>|
```

IKE automatically:

1. Authenticates the two endpoints.
2. Negotiates cryptographic algorithms.
3. Performs secure key exchange.
4. Creates IPSec SAs.
5. Establishes encryption and authentication keys.

Modern deployments should preferably use **IKEv2**.

C. Key Renewal and Revocation

- Configure SA lifetime limits.
- Renew keys before the current SA expires.
- Use automatic rekeying through IKE.
- Use strong random session keys.
- Immediately revoke compromised credentials.
- Maintain certificate/credential revocation mechanisms where certificates are used.
- Delete expired SAs automatically.
- Monitor failed negotiations and unusual rekey activity.

D. Scalability and Fault Tolerance

For large enterprises:

- Use centralized policy management.
- Automate IKE configuration.
- Use redundant VPN gateways.
- Maintain synchronized configurations.
- Use load balancing where appropriate.
- Monitor SA status centrally.
- Use multiple gateways to avoid a single point of failure.

Conclusion: An **IKEv2-based automated SA management system** provides better scalability, reliability, and security than manual key management.

3. PGP vs S/MIME for Secure Enterprise Email

A. Real-World Comparison

Feature	PGP	S/MIME
Trust model	Web of Trust	Certificate Authority
Key management	User-controlled	Centrally managed
Enterprise integration	Moderate	Excellent
Ease of administration	More complex	Easier
Email client support	Depends on software	Widely supported
Centralized control	Limited	Strong
Best suited for	Individual/technical users	Enterprises

PGP provides encryption and digital signatures using public/private keys and can operate through a decentralized trust model.

S/MIME uses X.509 digital certificates issued by trusted Certificate Authorities or enterprise PKI systems.

B. Key Management and Trust

PGP:

- Users generate their own key pairs.
- Public keys are exchanged between users.
- Trust can be established through signatures from other users.
- Key management can become difficult in large organizations.

S/MIME:

- Each user receives a digital certificate.
- Certificates are issued and managed through PKI.
- Trust is based on a certificate chain.
- Certificates can be revoked when compromised.

C. Recommendation

For a **financial services enterprise**, **S/MIME is generally recommended** because:

- It integrates well with enterprise email systems.
- Certificate management can be centralized.
- Organizational policies can be enforced.
- User identities can be tied to certificates.
- Certificate revocation and renewal can be automated.
- It provides encryption, authentication, integrity, and digital signatures.

PGP can still be appropriate for environments requiring decentralized trust or interoperability outside corporate PKI.

D. High-Level Implementation Workflow

Create Enterprise PKI
↓
Issue S/MIME Certificates
↓
Install Certificates in Email Clients
↓
Publish/Exchange Public Certificates
↓
Sender Signs Email
↓
Sender Encrypts Email
↓
Secure Email Transmission
↓
Receiver Decrypts Email
↓
Receiver Verifies Digital Signature

Conclusion: S/MIME is preferable for a large financial enterprise because centralized PKI provides better scalability, administration, and trust management.

4. Advanced Spam and Phishing Detection

A. Limitations of Existing Filtering

Basic filtering systems often depend heavily on:

- Simple keyword matching.
- Static blocklists.
- Sender addresses.
- Basic attachment filtering.
- Fixed spam thresholds.

Attackers can bypass these methods by changing wording, using newly created domains, spoofing addresses, or inserting malicious links.

B. Email Header Analysis

Important header indicators include:

- **From:** Check whether the displayed sender is genuine.
- **Return-Path:** Compare it with the sender domain.
- **Received:** Analyze the path taken by the email.
- **Reply-To:** Detect unexpected destination addresses.
- **Message-ID:** Identify suspicious or abnormal formats.
- **SPF:** Determines whether the sending server is authorized.
- **DKIM:** Verifies message-domain cryptographic signing.
- **DMARC:** Checks domain alignment and provides an anti-spoofing policy.

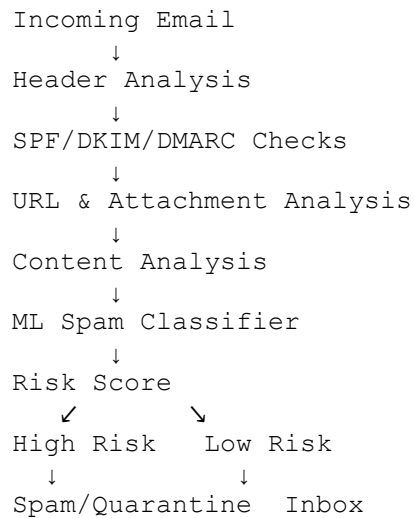
Suspicious indicators include:

From: trusted-bank.com
Return-Path: suspicious-domain.com
Received: unknown external server

Such inconsistencies increase the probability of phishing.

C. Improved Detection Model

A **hybrid rule-based + machine-learning model** can provide better detection.



Possible features include:

- Sender reputation.
- Domain age/reputation.
- SPF/DKIM/DMARC results.
- Number of URLs.
- Suspicious keywords.
- Message length.
- Attachment type.
- URL reputation.
- Linguistic characteristics.
- Previous user reports.

D. Effectiveness and False Positives

The system should assign a probability/risk score rather than relying on a single rule.

Example:

Score ≥ 0.90 → Quarantine
0.60–0.89 → Spam folder
< 0.60 → Inbox

False positives can be reduced using:

- Allow lists for trusted senders.
- User feedback.
- Continuous model training.
- Separate quarantine instead of immediate deletion.
- Periodic review of classification errors.

Conclusion: Combining header authentication, reputation analysis, content inspection, and machine learning provides stronger protection against modern spam and phishing attacks.

5. Secure S/MIME Certificate Management

A. Potential Certificate Vulnerabilities

Possible problems include:

- Expired certificates.
- Revoked certificates still being trusted.
- Self-signed or untrusted certificates.
- Incorrect certificate-to-user binding.
- Weak or compromised private keys.
- Improper certificate storage.
- Failure to validate certificate chains.
- Missing or outdated revocation information.
- Incorrect hostname/domain validation.
- Users accepting invalid certificate warnings.

B. Trust Chain and Validation

An S/MIME certificate should be validated through its certificate chain:

```

Root CA
  ↓
Intermediate CA
  ↓
User S/MIME Certificate
  ↓
Email Signature
  
```

The email client should verify:

1. Certificate signature.
2. Certificate validity period.
3. Trusted root CA.
4. Certificate chain.
5. Key usage and extended key usage.
6. Revocation status.
7. Identity/domain information.
8. Digital signature on the email.

If any important validation fails, the certificate should not automatically be trusted.

C. Secure Certificate Storage and Management

Recommended practices:

- Store private keys securely.
- Use encrypted key stores.
- Protect private keys with strong authentication.
- Use hardware-backed key protection where practical.
- Never share private keys.
- Maintain a centralized certificate inventory.
- Automate certificate renewal.
- Immediately revoke compromised certificates.
- Maintain secure backups where appropriate.
- Use enterprise PKI for centralized management.

D. User Awareness and System Configuration

Users should be trained to:

- Recognize certificate warnings.
- Never ignore invalid certificate messages.
- Protect their private keys.
- Report lost or compromised credentials.
- Verify unexpected signed emails.

Administrators should:

- Configure trusted CA stores correctly.
- Enforce certificate validation.
- Enable revocation checking.
- Monitor certificate expiration.
- Automate renewal.
- Remove obsolete certificates.
- Apply consistent S/MIME policies across email clients.

Conclusion: Secure S/MIME deployment requires not only encryption but also proper **certificate lifecycle management, trust-chain validation, private-key protection, revocation, and user awareness.**